

CS498 Week 2 - ROE and Scope

January 2026

Outline

This week will be focused on understanding Rules of Engagement (ROE), scope, and authorization for a penetration test. Before any technical testing begins, a professional pentest must have clearly defined boundaries and written permission. This protects the client, protects you, and ensures the results are valid and ethically obtained.

You will review industry guidance on pre-engagement planning, then use the provided worksheet and sample authorization forms to draft a simple ROE and Permission-to-Test memo for a fictional client scenario. These documents will be reused later when you begin lab work and will serve as the foundation for your methodology and reporting sections.

Material

- [YouTube: CompTIA PenTest+ Rules of Engagement](#)
- [YouTube: What is the Scope of a Pentest?](#)
- [PTES: Pre-engagement Interactions \(Scope vs ROE, Permission to Test\)](#)
- [NIST SP 800-115: Technical Guide to Information Security Testing and Assessment \(PDF\)](#)
 - Appendix B
- [NCC Group: Example Authorisation Form Example \(PDF\)](#)
- [SANS: Pen Test Rules of Engagement Example \(PDF\)](#)
- [Example Permission to Test Memo \(PDF\)](#)

Deliverables

- [Google Form for Quiz 2](#)

Quiz 2 Topics

- ROE vs. Scope
 - Scope = what is being tested (targets, IP ranges, applications)
 - ROE = how testing is performed (constraints, timeline, communications)
- Authorization and Permission-to-Test
 - Why written permission matters (legal/ethical protection)
 - Third-party permissions (cloud providers, vendors, managed services)
 - Contact and escalation paths (who to call if something breaks)
- Constraints and Safety Controls
 - Prohibited actions (DoS, phishing, password spraying) and why they are often restricted
 - Testing windows (change control, clinical hours, business operations)
 - Stop conditions
- Evidence and Data Handling Expectations
 - Evidence handling (naming conventions, timestamps, appendices)
 - Secure communication channels for sensitive information